Cyber.SoHo Educational Hub

From the Industry to the Classroom — Building the IT's Future, Today and Together!

Basics of Computer Networks

Day 06 — Network Security

The CIA Triad · Threats · Antimalware · Nmap · Firewalls · Troubleshooting

Final stage — Cyber.SoHo Network Build Challenge

4 contact hours · 2 h lectures · 2 h labs

© 2026 Cyber.SoHo Educational Hub — ALL Rights Reserved

Agenda — what's in this session

1. Lecture 1 — CIA triad, threat catalog, antimalware basics, Nmap / Zenmap & lab ethics (1 h)
2. Exercise 1 — Nmap / Zenmap lab on your own GNS3 topology (1 h class + 1 h home)
3. Lecture 2 — Configuring basic network security, troubleshooting methodology (1 h)
4. Exercise 2 — Project Stage 6: final integration & demo (1 h class + 1 h home)

> *By the end of today: a network you would not be embarrassed to hand to a real senior admin.*

LECTURE 1

The CIA Triad, the Threat Catalog, and the Ethics of Scanning

The CIA Triad — overview

Three properties every security decision must protect at least one of.

- **C — Confidentiality** — only the right eyes see the data
- **I — Integrity** — the data is unchanged in flight or at rest
- **A — Availability** — the data and the service are there when needed

> *If a control protects none of C, I, A — the control is decoration.*

CIA — what each leg means

Confidentiality

- Encryption
- File permissions
- Role-based access control
- WPA3 Wi-Fi

Integrity

- SHA-256 hashing
- Digital signatures
- File-integrity monitors
- Write-once log servers

Availability

- Redundancy
- Backup power
- DDoS mitigation
- Monitoring & alerting

> *Encrypt a file so hard nobody can read it = perfect C, zero A. That's not security — it's destruction.*

CIA — Key Takeaway

KEY TAKEAWAY

- Every security control must serve at least one of C, I, A — otherwise it is theatre.
- Defending one property does not defend the others. You need all three, balanced.
- Use C, I, A as the *lens* every time you review a design.

Threat Catalog — overview

Not every threat is a movie hacker. The real catalog is short.

- **Phishing family** — vishing (voice), smishing (SMS), phishing (email)
- **Malware** — virus, worm, trojan, RAT, ransomware, spyware, rootkit, fileless
- **DoS / DDoS** — flood the pipe or exhaust the state
- **Credential attacks** — brute force, password spraying, credential stuffing

> *Most real breaches start with one of these four. We will look at each.*

Smishing (1/2) — what it is

- **Definition** — SMS + phishing — a text message that pushes you to click, call, or pay
- **Why it works** — cheap, scalable, bypasses email filters
- **Common pretexts** — missed delivery, bank fraud alert, parking fine, tax refund

Anatomy of a smish:

- A scare or a reward
- A shortened or look-alike URL
- A fake login or payment page

Smishing (2/2) — six red flags in any URL

1. Wrong TLD (e.g. .xyz for what should be a .es brand)
2. Look-alike domain (correos-es.com vs correos.es)
3. Punycode / IDN homograph (Cyrillic look-alikes)
4. Mismatched subdomain (paypal.example.com)
5. Raw IP address in the URL
6. Unusual port (e.g. :8080)

KEY TAKEAWAY

- If even one heuristic trips, do not click. Verify out-of-band — phone the bank using the number on the back of the card.

Malware taxonomy (1/2)

- **Virus** — needs a host file; spreads when the host runs
- **Worm** — self-propagating; spreads over the network without user action
- **Trojan** — looks legitimate, hides a malicious payload
- **RAT (Remote Access Trojan)** — gives the attacker live remote control of the host

Malware taxonomy (2/2)

- **Ransomware** — encrypts data, demands payment for decryption
- **Spyware / keylogger** — silent observation of what the user types
- **Rootkit** — hides itself and other malware from the operating system
- **Fileless malware** — lives in RAM; abuses legitimate tools (PowerShell, WMI)

KEY TAKEAWAY

- Modern malware is rarely one type — it's a chain: phishing → trojan → RAT → ransomware.

DoS vs DDoS — distinction

Denial of Service

- One attacker, one source, one victim
- Easy to block at the source IP

Distributed Denial of Service

- Many sources (a botnet), one victim
- Cannot just block one IP

Attack flavours:

- **Volumetric** — fill the pipe (Gbps of garbage)
- **Protocol** — exhaust the state table (SYN flood)
- **Application** — slow HTTP, expensive queries (Slowloris)

DDoS — defences

1. Upstream scrubbing (Cloudflare, Akamai, your ISP)
2. Rate limiting at the edge
3. SYN cookies — defeats SYN floods
4. Connection timeouts — defeats slow-HTTP attacks
5. Geo-blocking if you only serve one region

KEY TAKEAWAY

- You cannot defend a DDoS from inside the pipe. The fight happens upstream, at the ISP or scrubbing provider.

Brute force vs Password spraying (1/2)

Attribute	Brute force	Password spraying
Shape	Many passwords against ONE user	Few common passwords against MANY users
Lockout risk	High — trips lockout fast	Low — stays under threshold
Detection signal	Many fails per one user in a short window	One password tried across many users
Typical target	Single high-value account (admin, exec)	Whole user directory (M365, Google Workspace)

Brute force vs Password spraying (2/2) — defences

- **MFA on every account that matters** — the single biggest win
- **Account lockout after N failures** — catches brute force
- **Rate-limit by source IP** — catches both shapes
- **Impossible-travel detection** — catches stolen credentials
- **Monitor failures by password** — catches spraying that lockout misses

KEY TAKEAWAY

- Lockout alone catches brute force but misses spraying. You must also monitor by password.

Threats — Key Takeaway

KEY TAKEAWAY

- Most real breaches start with phishing, not zero-days.
- Malware is a chain, not a single thing.
- DDoS is fought upstream — at the ISP or scrubbing provider, never inside.
- Credential attacks are about visibility — detect the shape, not just the count.

Antimalware — defence in depth

- **Endpoint AV / EDR** — signatures + behavioural heuristics
- **Email filtering** — kill the phishing payload before it reaches the user
- **DNS filtering** — block known-malicious domains at resolution time
- **Application allow-listing** — only signed binaries can run
- **Patching** — close the holes the malware exploits
- **Backups** — the ultimate ransomware defence — offline, tested

Antimalware — verify before you run

For any installer downloaded from the internet:

1. Get the SHA-256 of the file
2. Submit the hash (not the file) to VirusTotal — keeps your file private
3. Check the multi-engine result before running
4. Cross-check the vendor's published hash on their site

KEY TAKEAWAY

- Verifying a hash takes 30 seconds and beats every fancy EDR for the question 'is this installer safe?'

Nmap / Zenmap — purpose

- **Nmap** — reference open-source network scanner — host discovery, port scan, service & OS detection
- **Zenmap** — official GUI front-end — adds topology and services visualisations

Why we use them in this course:

- Inventory our own network
- Find drift between the IP plan (what we *meant* to build) and reality
- Catch unexpected open ports before an attacker does

Nmap — the legal / ethical line

> *You scan only what you own, or what you have written permission to test. Full stop.*

A port scan against someone else's network is unauthorised access in most jurisdictions:

- **Spain** — Ley Orgánica 10/1995, arts. 197 bis / ter / quater
- **EU** — Directive 2013/40/EU — attacks against information systems
- **US** — Computer Fraud and Abuse Act (CFAA)
- **Canada** — Criminal Code s.342.1

KEY TAKEAWAY

- 'I was just looking' is not a defence. Stay inside your own lab.

Nmap — common flags

Flag	Meaning
-sn	Ping scan — host discovery only, no port scan
-sV	Service & version detection on each open port
-sU	UDP scan (pair with --top-ports — UDP is slow)
-p-	Scan all 65 535 TCP ports
--top-ports N	Scan only the N most common ports
-T0 … -T5	Timing — 0 paranoid, 4 quick, 5 insane
-A	Aggressive: -sV + OS detect + scripts + traceroute
--exclude HOST	Skip a specific host (or --exclude-file)

Lecture 1 — Key Takeaway

KEY TAKEAWAY

- CIA is the lens — every control protects at least one of C, I, A.
- The real threat catalog is short: phishing, malware, DDoS, credentials.
- Defence in depth beats any single product.
- Recon tools are powerful — and misuse is a crime. Stay inside your lab.

EXERCISE 1

Nmap / Zenmap Lab on Your Own GNS3 Topology

Exercise 1 — setup checklist

Before you scan, confirm every item below works:

- **nmap --version works** — Linux, macOS terminal, or Windows PowerShell
- **Zenmap GUI installed** — shipped with the Windows installer
- **GNS3 project from Day 5 running** — Start/Resume all nodes
- **Cloud node bridged to host LAN** — Edit > Preferences > Cloud nodes
- **Day 04 IP plan in front of you** — we will cross-check against it
- **Wireshark open in the background** — to see the packets Nmap sends

> *Fix any failure before scanning. Do not work around it.*

Exercise 1 — procedure (1/2)

1. Identify the target subnet from your Day 04 plan — write it on paper
2. Sanity ping the gateway from a VPCS host inside GNS3
3. Host discovery — find every live host on the subnet
4. Service scan — list services on the live hosts

```
$ nmap -sn 192.168.10.0/24
      # -sn  =  ping scan only, no port scan

$ nmap -sV -T4 --top-ports 100 192.168.10.0/24
      # -sV         =  service & version detection
      # -T4         =  fast (but polite) timing
      # --top-ports =  scan only the 100 most common ports
```

Exercise 1 — procedure (2/2)

1. Open Zenmap — paste the same target, run the 'Intense scan' profile, take a screenshot of the Topology tab
2. Wireshark sanity — filter ip.dst == 192.168.10.0/24, watch the probes
3. At home — compare two more profiles to feel the trade-off:

```
$ nmap -T5 -p- 192.168.10.0/24            # loud  — every TCP port
$ nmap -T2 --top-ports 50 192.168.10.0/24  # polite — slow, quiet
```

> *Loud profile will set off any real IDS. Polite profile is closer to a legal external scan.*

Exercise 1 — deliverables

A one-page report containing:

- Target subnet and scan time
- Host-discovery table (IP, MAC, expected? Y/N)
- Service table (host, port, service, expected? Y/N, follow-up?)
- Zenmap Topology screenshot
- One paragraph: 'What surprised me. What I would change in my IP plan.'

KEY TAKEAWAY

- This page slots straight into your Exercise 2 final hand-in.

LECTURE 2

Configuring Basic Network Security & Troubleshooting

Authentication — the three factors

1. Something you KNOW — password, PIN, security question
2. Something you HAVE — phone, hardware token, smart card
3. Something you ARE — fingerprint, face, iris

MFA = combine factors from DIFFERENT categories

- **Two passwords ≠ MFA** — same factor
- **Password + TOTP code = MFA** — different factors
- **Password + fingerprint = MFA** — different factors

MFA — flow

1. User enters username + password (factor 1)
2. Server validates — if good, prompts for second factor
3. User submits TOTP code from authenticator (factor 2)
4. Server verifies the 6-digit code against the shared secret
5. Session established

Common second-factor methods (best → worst):

- Hardware key (FIDO2 / WebAuthn) · TOTP authenticator app · Push notification · SMS (avoid — SIM-swap risk)

TOTP — how it works

TOTP — Time-based One-Time Password (RFC 6238)

1. Server and client share a secret seed (provisioned via QR code)
2. Current 30-second time window is hashed with the seed using HMAC-SHA1
3. The output is truncated to 6 digits
4. Both sides compute the same code from the same time + same seed

> *No network call needed — the code is computed, not delivered. Works on a plane.*

Password hygiene — modern guidance (NIST SP 800-63)

- **Length > complexity** — a 16-character passphrase beats P@ssw0rd!
- **Never reuse between sites** — use a password manager
- **Check against breach lists** — HaveIBeenPwned
- **No forced rotation** — unless compromise is suspected
- **Always pair with MFA** — on anything that matters

KEY TAKEAWAY

- The password is the weakest factor — protect it with a manager, back it with MFA.

Wi-Fi standards — WEP → WPA3

Standard	Year	Status today
WEP	1997	Broken — never use
WPA	2003	Deprecated
WPA2-PSK	2004	Vulnerable to offline dictionary attacks
WPA2-Enterprise	2004	OK with strong 802.1X
WPA3-Personal	2018	SAE handshake — modern default
WPA3-Enterprise	2018	192-bit suite for high-security environments

Wi-Fi hardening — three-SSID strategy

1. Corp — WPA3-Enterprise · 802.1X · tagged VLAN · full LAN access
2. Guest — WPA3-Personal · daily-rotating PSK · isolated VLAN · internet only
3. IoT — WPA3-Personal · fixed PSK · no LAN · no internet by default

Extra hardening — everywhere:

- Disable WPS · Strong passphrase ≥ 16 chars · Update firmware · Disable legacy 802.11b/g if possible

KEY TAKEAWAY

- Segment by trust, not by convenience.

Firewalls — what they do

A firewall filters traffic based on a policy.

- Sits between two or more network zones
- Decides per-packet: allow · drop · reject · log
- Can match on src/dst IP, port, protocol, interface, time, connection state, even application-layer content

Where they sit:

- **Network firewall** — Cisco router ACL · pfSense · OPNsense · perimeter device
- **Host firewall** — iptables / nftables · Windows Firewall · macOS pf

Stateful vs stateless

Stateless (packet filter)

- Inspects each packet in isolation
- Fast, simple, no memory of past packets
- Use case: Cisco standard ACL

Stateful (connection tracker)

- Remembers connection state (NEW, ESTABLISHED, RELATED)
- Replies to outbound connections are auto-permitted
- Use case: iptables conntrack, nftables, modern routers

Modern default = stateful. Stateless survives only where speed beats sophistication.

Cisco extended ACL — syntax

```
ip access-list extended FROM-INTERNET
  permit tcp any any established
  permit icmp any any echo-reply
  permit icmp any any unreachable
  deny ip any any log
exit
interface GigabitEthernet0/0
  ip access-group FROM-INTERNET in
```

- **established** — TCP packets with ACK or RST — return traffic
- **log on the final deny** — capture attempts in the router log
- **Direction** — apply inbound on the WAN interface

Linux firewall — iptables / nftables / ufw

iptables (classic)

```
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
iptables -A INPUT -p tcp --dport 22 -s 192.168.10.0/24 -j ACCEPT
iptables -P INPUT DROP
```

nftables (modern)

```
nft add rule inet filter input ct state established,related accept
nft add rule inet filter input tcp dport 22 ip saddr 192.168.10.0/24 accept
```

ufw (Ubuntu front-end)

```
ufw default deny incoming
ufw allow from 192.168.10.0/24 to any port 22
```

Windows firewall — PowerShell

```
New-NetFirewallRule -DisplayName "Allow SSH from LAN" `
  -Direction Inbound -Protocol TCP -LocalPort 22 `
  -RemoteAddress 192.168.10.0/24 -Action Allow
```

- **Three profiles** — Domain · Private · Public — set rules per profile
- **Inspect** — Get-NetFirewallRule and Get-NetFirewallProfile
- **Defaults** — sane on modern Windows — don't disable the whole thing

KEY TAKEAWAY

- Every OS has a built-in firewall. Use it. Default-deny inbound.

Firewalls — Key Takeaway

KEY TAKEAWAY

- Default-deny inbound. Allow only what you understand.
- Stateful filtering is the modern default — return traffic disappears into the conntrack table.
- Apply ACLs inbound on the untrusted interface (your WAN).
- Log the deny — you cannot defend what you cannot see.

Troubleshooting — methodology

Four phases, in order, every time:

1. GATHER — what's broken, when did it start, what changed?
2. ISOLATE — walk the OSI stack: L1 → L2 → L3 → L4 → L7
3. RESOLVE — apply the smallest possible change that fixes it
4. DOCUMENT — runbook · ticket · README · future-you will thank you

> *'It worked yesterday' is a starting clue, not an explanation.*

Troubleshooting — the OSI walk

Layer	Question	Tool / command
L1	Link light on?	NIC LED · ip link
L2	Got a MAC neighbour?	arp -a · ip neigh
L3 (LAN)	Ping the gateway?	ping <gw>
L3 (WAN)	Ping 8.8.8.8?	ping 8.8.8.8
L7-DNS	Resolve a name?	nslookup · dig
L4	TCP handshake to port?	nc -zv · Test-NetConnection
L7-App	App returns 200?	curl -v

Troubleshooting — Key Takeaway

KEY TAKEAWAY

- Walk layer by layer — don't jump to the app before you ping the gateway.
- Change one thing at a time. Re-test after each change.
- If you can't reproduce it, you didn't fix it.
- Document while it's fresh — not after the next outage.

EXERCISE 2

Project Stage 6 — Final Integration & Demo

Exercise 2 — WAN inbound ACL (the final firewall)

```
enable
configure terminal
  ip access-list extended FROM-INTERNET
    permit tcp any any established
    permit icmp any any echo-reply
    permit icmp any any unreachable
    deny ip any any log
  exit
  interface GigabitEthernet0/0
    ip access-group FROM-INTERNET in
end
write memory
```

KEY TAKEAWAY

- Verify: outbound internet still works · inbound port 22 from cloud now times out.

Exercise 2 — deliverables

Folder final_project_<your-initials>/ must contain:

- **topology.png** — screenshot of the GNS3 workspace, all nodes labelled
- **ip_plan.csv** — your IP plan from Day 04, updated if anything changed
- **firewall_rules.txt** — the ACL exactly as applied to the router
- **nmap_inventory.txt** — output of nmap -sV --top-ports 100 ... from Exercise 1
- **README.md** — the 1-page documentation (template next slide)

README — 1-page template

Sections to fill in — keep it to ONE printed page:

1. Author — your name
2. Topology summary — two LANs + router + Wi-Fi
3. IP plan table — subnet, purpose, DHCP, notes
4. Internal services — DNS, HTTP — name → IP
5. Firewall stance — the 4-line ACL
6. Known gaps / future work — MFA, log forwarding, IoT VLAN
7. Next course — recommendation: CCNA — Introduction to Networks (ITN)

Hyperlinks & references — summary

- **Standards & bodies** — IEEE · IETF · ISO · Wi-Fi Alliance · NIST · CCN-CERT · ACM · IEEE Code of Ethics
- **Legal references** — ES Ley Orgánica 10/1995 · EU Directive 2013/40/EU · US CFAA · CA Criminal Code s.342.1
- **Tools** — Nmap · Wireshark · GNS3 · VirtualBox · KVM · VMware Workstation Pro · Cisco CML · Cisco Packet Tracer
- **Companion course** — Cisco NetAcad — Networking Essentials 3.0
- **YouTube channels referenced** — Professor Messer · NetworkChuck · PowerCert · David Bombal · IBM Technology

Disclaimer (1/2) — IP & affiliation

- **Intellectual Property** — Cyber.SoHo Educational Hub is the sole creator and owner of every part of this material. © 2026. ALL Rights Reserved.

- **No institutional affiliation** — Cyber.SoHo is independent. Not affiliated with Cisco, Microsoft, Google, the IEEE, NIST, the Wi-Fi Alliance, or any other third party. All trademarks belong to their respective owners.

- **YouTube videos** — Linked only — never embedded or re-hosted. Watch on the original creator's channel.

Disclaimer (2/2) — verification, liability & ethics

- **Verify your installers** — Always check downloaded installers via VirusTotal (virustotal.com) before running.

- **Liability & ethics** — Labs are designed for YOUR OWN GNS3 environment. Running recon tools against systems you do not own may constitute a criminal offence under: ES Ley Orgánica 10/1995 · EU Directive 2013/40/EU · US CFAA · CA Criminal Code s.342.1. Reinforced by ACM and IEEE Codes of Ethics.

> *Cyber.SoHo accepts no liability for misuse.*

End of course — where to go next

Recommended follow-ons:

- **CCNA — Introduction to Networks (ITN)** — natural follow-on at Cisco NetAcad
- **CompTIA Network+ / Security+** — vendor-neutral fundamentals
- **TryHackMe / HackTheBox** — practical labs on YOUR OWN VMs only

What you can do now:

- Design a small LAN with VLANs, DHCP, DNS, internal HTTP, Wi-Fi, and a default-deny WAN ACL
- Inventory a network with Nmap — verify open ports against an IP plan
- Walk an outage from L1 to L7 without panic

> *Welcome to the end of the course. Go build something.*

Cyber.SoHo Educational Hub

From the Industry to the Classroom — Building the IT's Future, Today and Together!

© 2026 Cyber.SoHo Educational Hub · ALL Rights Reserved

Thank you.